

AI Critique — HW06

MSSV: 23127044

Word count: ~280 từ

Qua ba API (Profile, Order State, Admin Orders), AI (Cursor Agent) cho output ban đầu **đủ số lượng** test case nhưng **thiếu chiều sâu** khi đối chiếu source code SUT. Điểm yếu lớn nhất là AI **mặc định backend validate giống frontend**: với FR-04, AI gán expected 400 cho phone sai regex hoặc name rỗng, trong khi `server.js` không hề kiểm tra — chỉ frontend `Profile.jsx` mới reject. Khi audit bằng HW02, sáu TC phải sửa label INVALID và điều chỉnh expected theo hành vi thực tế, không theo spec lý tưởng.

Thứ hai, AI **liệt kê SEC-06/SEC-03 trừu tượng** nhưng không viết TC executable cho privilege escalation (`role=admin` trong body) hay user token truy cập admin API. Các TC extend (API1-E-01, API3-E-01) tồn tại vì AI không đọc `server.js` lines 124–127 và 510–523 — nơi role update và admin list **không có role middleware**. Newman chạy thật cho thấy TC expect 403 sẽ FAIL, biến thành bằng chứng bug — đúng mục tiêu HW06.

Thứ ba, với state machine FR-10, AI mô tả đúng diagram hợp lệ nhưng **bỏ sót transition bị bug**: `canceled→delivered` (BUG-B1) và user cancel khi `shipping` (BUG-B3). AI coi terminal state là điểm dừng thiết kế, không test "cái lẽ ra phải bị chặn". BVA phone cũng sai hướng: AI dùng regex làm oracle thay vì nghiệp vụ VN (số bắt đầu 0).

Bài học: Pipeline AI→Audit→Extend→Newman là cần thiết; AI generate nhanh partition/schema khung, nhưng **human audit bắt buộc** phải đọc code + tái sử dụng bug HW02. Prompt step-by-step (từng biến, từng SEC) hiệu quả hơn một prompt "generate all tests". Extend ≥5 TC/API không phải optional — đó là nơi bắt được lỗ hổng mà AI systematically miss.

Export PDF: [TODO user export ai-critique.pdf]